

B1.

NorthSound Finance is a financial services firm that handles the sensitive data of its customers. They experienced an incident that had occurred when an employee received a fraudulent email, clicked a malicious link, and then entered their credentials on the attacker's site. This incident had been a targeted phishing campaign sent to multiple employees in a small time frame. The employee who had gotten their credentials stolen was also a victim of malware that had been installed on their workstation.

B2.

Because this employee's account was compromised and they held Administrative privileges, the exposure of their credentials carried an elevated risk to not only their account but also the financial data of NorthSound Finance's customers. The impact was promptly contained to a single account and workstation, and there was no further evidence of any lateral movement or exposure on other additional systems, customers, or the domain.

B3.

The Security Operations team had investigated the incident, confirmed the root cause, and commenced a remediation procedure. The actions included resetting and disabling the compromised account, blocking the attacker's address at the firewall, removing the existing malware on the workstation, and eliminating the attacker's persistence.

B4.

The incident had been fully resolved after creating new rules within the internal and external firewalls, making the host of the attackers' site unreachable, all malware had been removed, and the affected account was disabled and reset. After all the SOC actions had been completed, the Security Operations Manager had confirmed the remediation procedures were successful, and the incident for the ticket was officially closed.

B5.

To reduce the risk of these incidents in the future NorthSound Finance should implement a multifactor authentication for its employees, it allows for an extra layer of protection and prevents attackers from gaining access easily, they should also implement email authentication, anti-phishing controls, least privilege access so only specific users are admins and not everyone is a local administrator, and they should also provide some kind of education training on phishing awareness so that employees are aware when these emails appear.

C1.

NorthSound Finance is a financial services firm that handles the sensitive financial data of its customers, making it a target for possible cyberattacks. This report documents an incident in which an employee fell victim to a phishing campaign that compromised their credentials. The investigation details the response that followed the phases of the NIST incident response framework (preparation, detection, analysis, containment, eradication, recovery, and post-incident activity) (Cichonski et al., 2012). The symptoms that were observed included multiple reports that were made about the suspicious "Employee Satisfaction Survey" email and an employee who clicked the link and entered their credentials, as well as activity that was traced to the affected workstation.

C2.

The purpose of this report is to document the investigation and the remediation procedures in detail that were made for the phishing incident, which included the actions that were taken, the evidence collected, and the outcomes. The scope covers the compromised account and the affected workstation, the attacker's infrastructure, and recommendations on how to reduce similar risks for future incidents.

C3.

The intended audience includes both the business stakeholders and the technical team at NorthSound Finance. As the technical stakeholders, this includes the Security Operations Manager (Samira Nadeem) and the IT and security teams, who are responsible for remediation and response for such incidents. The business stakeholders include the executive leadership, such as the CEO, Maya Kwon, who must understand the importance of how an incident may impact the protection of customer data.

D1.

The first indicators that appeared were the user and helpdesk reports within the investigator's mailbox. The Security Operations Manager had forwarded a report that was made from an employee (c.ortiz) who had clicked a suspicious link with the subject line "Employee Satisfaction Survey" within their email and had entered their credentials. Two helpdesk tickets, 3149 and #3152, were also reporting the same email. Since multiple independent reports were made within minutes, it signaled that this was a targeted phishing campaign being sent within the company.

D2.

The key evidence collected included the phishing email itself and the headers, which had shown the typosquatted sender domain and a link to the attacker's host at the address 203.0.113.10:8080. The SIEM logs had also shown that the user submitted credentials to that host, a stager download, and update.exe being written to the workstation. The authentication events also showed that the activity had originated from the user's own machine at 10.0.0.149,

which meant that it wasn't a remote host. After examination of the workstation, it was revealed that the HKLM Run key entry and a rogue local administrator account attached to the svc_update had been malicious and made their way into the workstation.

D3.

The first was that a phishing attack had harvested the user's credentials and established local persistence by delivering a payload. The second was that the account had been compromised through a remote takeover from an external host, with the possibility of it moving laterally through the Active Directory-based privilege and affecting other users.

D4.

The phishing hypothesis was the main cause that had been determined after the investigation was completed. It was supported by the SIEM logs showing the credentials were submitted to the attacker's host 203.0.113.10, the stager download, and the update.exe being installed into the compromised account's workstation, along with the Run key and the rogue svc_update found locally within the administrator's account. The remote takeover hypothesis was debunked because the account's authentication activity showed that it had only originated from the user's own workstation 10.0.0.149 and not an external host. As for the Active Directory escalation hypothesis, this was also ruled out because after reviewing the Active Directory, it showed that no attacker had created any domain accounts, and none of the privileges were changed within the domain groups, and no signs of lateral movement to the other systems were found, which confirms that the persistence was only established locally on the machine rather than the domain itself.

E1.

The investigation began when a report was made and landed within the investigator's mailbox, which entailed a suspicious survey email that had been sent to multiple users. After examining the email and its headers within Thunderbird, it revealed a typosquatted sender domain with a link to an attacker-hosted address at 203.0.113.10:8080. After the investigator had identified this, a log analysis was done within Elastic/Kibana SIEM, which had shown that the attack chain was the user submitting their credentials, a stager download, and update.exe was written to the workstation. The authentication events had also confirmed this activity came from a specific user's own machine 10.0.0.149 not a remote host. By going into the workstation of that user and viewing their registry keys and local accounts, it was discovered that the persistence was a malicious HKLM Run key and a rogue admin account attached to svc_update. This had established the root cause as a successful phishing attack that was made by harvesting credentials and delivering a payload within the user's workstation, which allowed the attacker to temporarily obtain local administrative access.

E2.

The tools that were used by the investigator were a few, but the first one was Thunderbird, as it was used to examine the phishing email and its headers to confirm if the domain was a spoof, as

well as the malicious link. The next tool that was used was Kibana SIEM, which was used to view the internal logs within the network, and it revealed the credentials being stolen, payload download, and the source IP. The Registry Editor and Command Prompt were the next tools used, which also showed that the HKLM Run key and the rogue svc_update were on the user's workstation. Active Directory Users and Computers was used on the domain controller to reset and disable the compromised account. The last tool that was used was pfSense, as it helped the investigator create rules within the firewalls that blocked the attacker's host traffic, verified using the ping diagnostic.

E3.

The firewall block that was made had been validated by commencing a ping to the address 203.0.113.10, and it had received 100% packet loss, and the malicious page timed out when loaded. The malware removal was also confirmed by the update.exe process no longer running within the Task Manager, and the Run key was gone. The persistence removal was also verified by re-checking the accounts within the local administrator and confirming the svc_update was deleted as well as the c.ortiz account. The ticket closure notification was also sent within the investigator's email inbox, and an additional email from the Security Operations Manager acknowledging the final confirmation of the incident had been remediated.

E4.

There were two challenges that arose from this, and the first one was that the SIEM searches had initially returned practically nothing because the logs predated the default time range being searched. This was corrected by expanding the search window to the last year of activity. The second was that the update.exe couldn't be deleted at first because the process was still running in the background; after checking the Task Manager, it was terminated and successfully deleted.

F1.

The incident was contained and resolved by containing the compromise of the stolen credentials. Disabling the affected account (c.ortiz) and resetting the password revoked any active sessions and required the user to log in with new, valid credentials. The attacker's host address 203.0.113.10 was also blocked on both internal and external firewalls, and the state table was reset to ensure any existing connections were dropped. This was also verified by doing a ping test and getting a return of 100% packet loss. To completely eliminate the threat, the running update.exe process within the Task Manager was terminated and deleted, and the HKLM Run Key was also deleted. Lastly, the rogue svc_update was also deleted as it was identified as a persistence within the administrators group, so removing c.ortiz as well had resolved this incident. The Security Operations Manager had also confirmed that the remediation was successful and the incident ticket was closed.

F2.

The remediation was targeted, and it caused minimal disruption to the network. By disabling the c.ortiz account, the user's access was temporarily removed, and this needed to be done as a

necessary containment measure. The workstation also remained completely operational throughout this investigation. The malware and the rogue account were both successfully removed without needing to reimage the entire system, so all files were kept intact. The firewall rules helped block the traffic sent to the host, as this investigation was being done to prevent any unknown authorization from occurring, but after conducting the investigation, there were no signs of lateral movement, and no other systems or users were impacted by this attack.

F3.

As a financial services firm, the company NorthSound Finance must hold a standard to the Gramm-Leach-Bliley Act (GLBA), whose Safeguards Rule requires companies in this industry to protect customer nonpublic information and have incident response capabilities (Federal Trade Commission, n.d.). The remediation that was completed supported these requirements, such as resetting and disabling the compromised account, blocking the exfiltration host, which protected customer financial data from being exposed any further, while also removing the malware and attacker presence that affected the integrity of the affected system. Documenting the investigation and its response through evidence allowed for a clear, concise, detailed description of everything that was done, and it supports GLBA's expectations that security incidents be identified, responded to, and recorded.

F4.

Residual Risk 1

Risk Description: A user can still fall for phishing emails because there's no extra layer of security, such as multifactor authentication (MFA), in place that would be able to protect accounts if their credentials are stolen.

Threat Source: External attackers using phishing or social engineering campaigns

Remaining Vulnerability: A single-layer factor of authentication. If credentials are stolen, an attacker would only need this to gain account access.

Potential Impact: If a user's credentials are stolen again, it could lead to unauthorized access to customer financial data and its systems.

Likelihood: High. Phishing attempts are very common and a recurring attack. This incident showed that the employees will click on malicious links unaware of it being a potential phishing attempt, so without MFA, it leaves the methodology unmitigated and open to attacks again unless an implementation of MFA is made within the company.

Severity: High. Compromised credentials of privileged users, especially, can lead to direct exposure of data and compromise other important factors within the network.

Residual Risk 2

Risk Description: A standard user may still be able to hold local administrator rights on their workstations, which allows for a compromised account to give attackers elevated privileges regardless of who they target.

Threat Source: Malware or an attacker that gains a foothold on the workstation through a compromised standard-user account.

Remaining Vulnerability: Allowing standard users to have local privileges, which violates least-privilege principles.

Potential Impact: An attacker could install malware and create persistence as well as disable security controls because a compromised account with local admin rights grants elevated access, as occurred in this incident.

Likelihood: Medium. This depends on the user being attacked; some users may be able to notice the suspicious phishing attempt, but others may not. This incident has proven that there is still a lack of authentication security when logging into accounts.

Severity: High. The local administrative access enables persistence with system-level changes, which could be difficult to detect and remove at times.

G.

The report addressed a phishing incident that had occurred within NorthSound Finance, where an employee's credentials were compromised, and malware was written onto their workstation. After careful examination, the technical solution was resetting and disabling the affected user's account, blocking the attacker's host through external and internal firewalls, removing the malware, and terminating the attacker's local persistence. After this was completed, the threat was fully contained and eradicated, which strengthened the organization's security. To avoid future compromising of accounts, an implementation of security controls such as multifactor authentication and least privilege access is highly recommended, as this will reduce the risk of similar incidents occurring and protect the company's customer data moving forward.

References

Cichonski, P., Millar, T., Grance, T., & Scarfone, K. (2012). Computer security incident handling guide (NIST Special Publication 800-61 Revision 2). National Institute of Standards and Technology.
<https://doi.org/10.6028/NIST.SP.800-61r2>

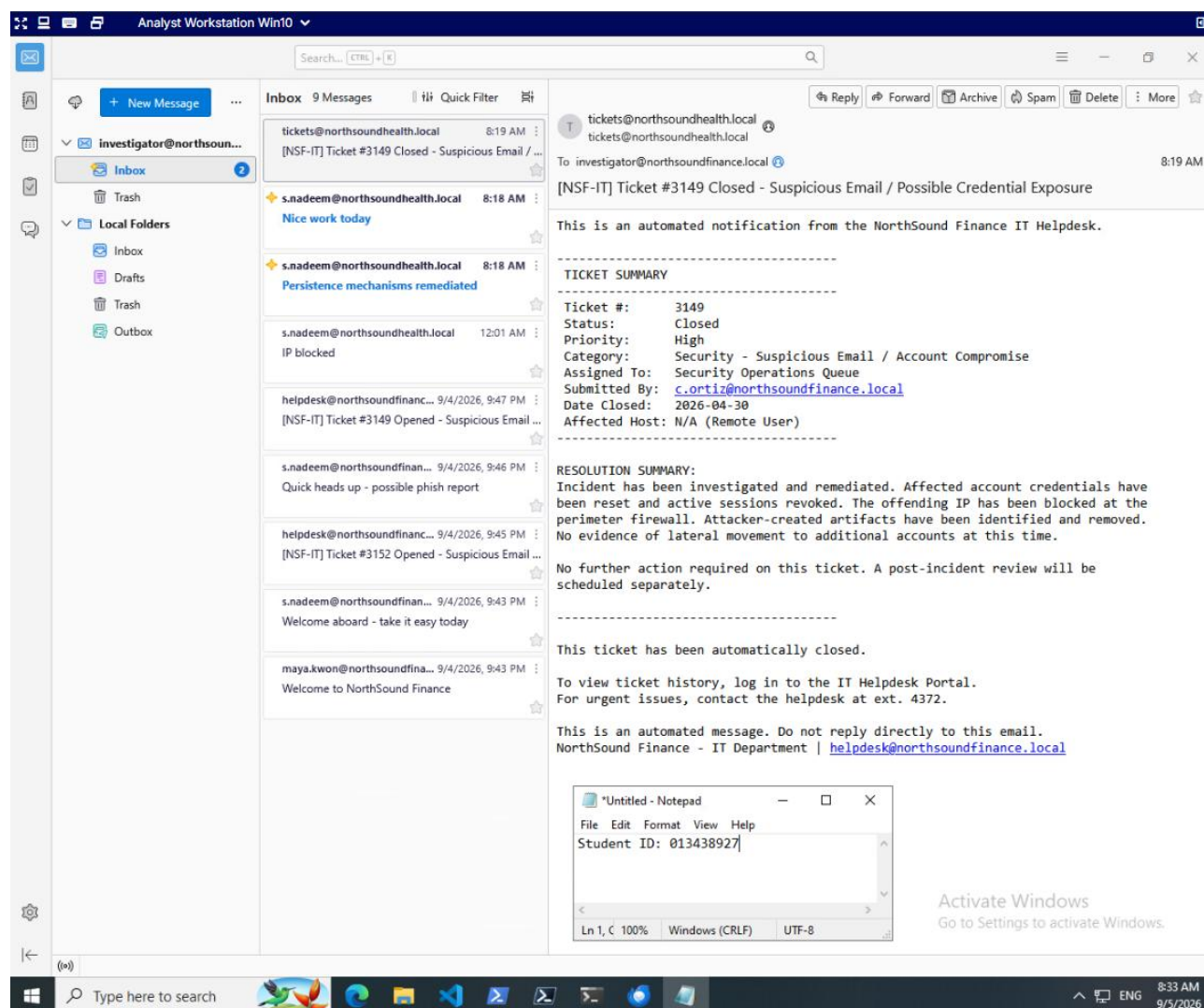
Federal Trade Commission. (n.d.). Gramm-Leach-Bliley Act.
<https://www.ftc.gov/business-guidance/privacy-security/gramm-leach-bliley-act>

Appendix A

This appendix illustrates the completed Evidence Log, Decision Log, and the entire Incident Summary that was compiled while working in the Workplace Experience Lab. It also contains screenshots that were collected during the process to document the investigation and remediation of the entire phishing incident that had occurred at NorthSound Finance.

Completion Verification

The following screenshot shows the completion of the lab remediation, and it shows that the automated closed ticket notification for ticket #3149, which had landed in the investigator's inbox, includes the date and time, and the student ID.



Evidence Log

The Evidence Log had documented each item during the investigation, showing what was found and why it mattered.

Evidence Log Entry 1 – The First Indicators

Artifact type: Email

Source: Investigator mailbox, NSF IT Helpdesk

Evidence: A report was made by S. Nadeem, the Security Operations Manager, and two helpdesk tickets (#3149 and #3152) reported a suspicious email with the subject being "Employee Satisfaction Survey" appearing in the inbox of users.

Key Findings: A user named Caleb Ortiz (c.ortiz) clicked the link and entered his credentials, compromising his account. A second user named d.ruiz received the same email within his inbox, but did not click the link. There were multiple independent reports that were made within a few minutes of the targeted phishing campaign that was indicated.

Relevance: This marks the initial detection being made and that the user c.ortiz is the likely victim account.

Supports which hypothesis? Initial hypothesis

Image 1 – Security Operations Manager forwarded a report from c.ortiz describing the clicked survey link.

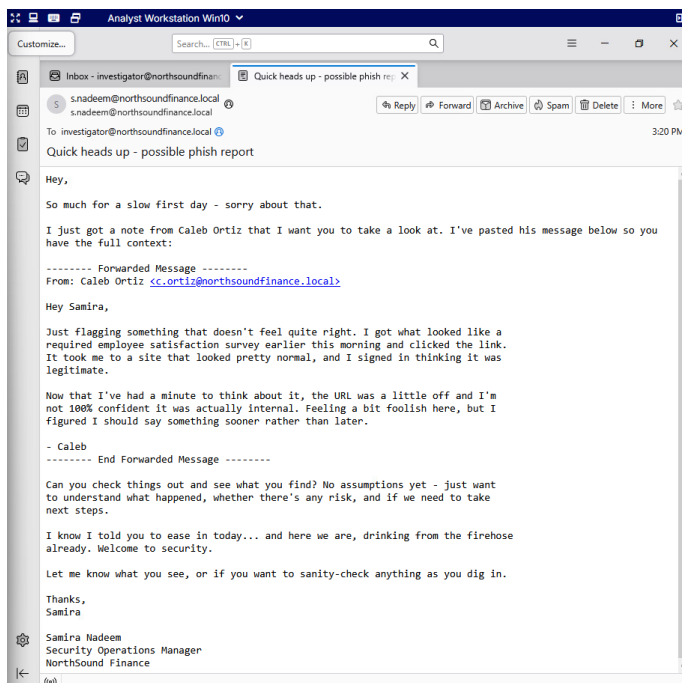


Image 2 – The helpdesk ticket #3149 showing the exposure of credentials reported by c.ortiz

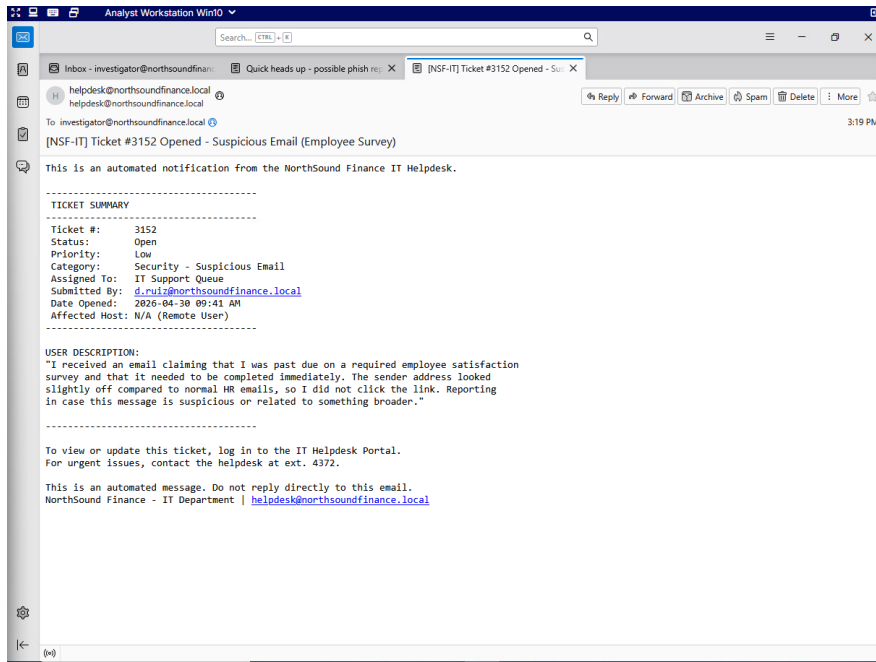
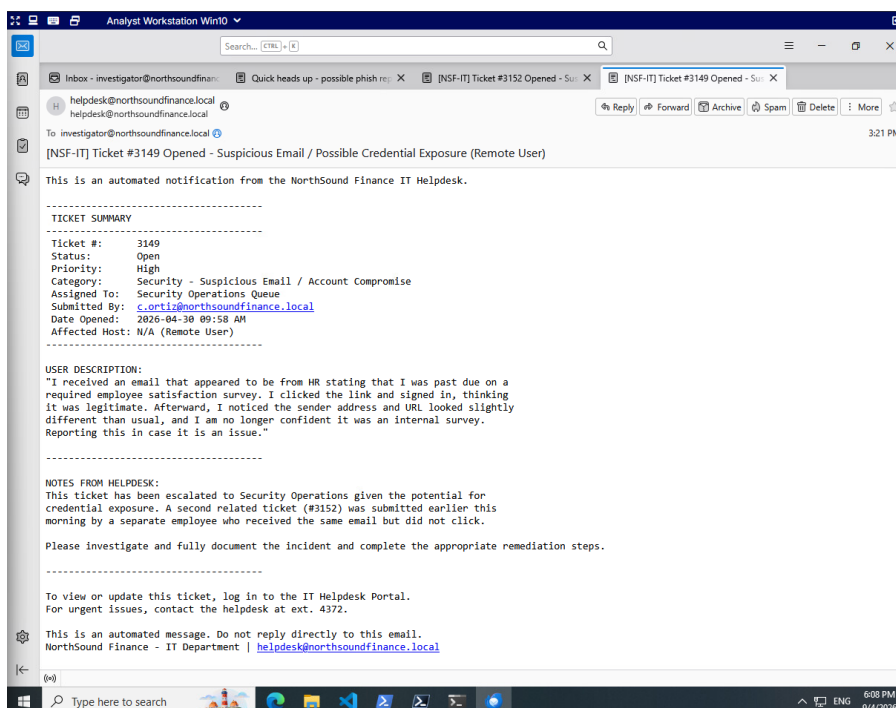


Image 3 – The helpdesk ticket #3152 explaining the same email was received by d.ruiz, but didn't click the link.



Evidence Log Entry 2 – Phishing Email Analysis

Artifact Type: Email

Source: Investigator mailbox within Thunderbird

Evidence: The phishing email from the account hr@n0rthsoundfinance.org had contained a link to <http://203.0.113.10:8080/survey>

Key Findings: The sender's email address domain was "n0rthsoundfinance.org" – this is a typosquatted lookalike to the company's original domain (Replaced the o with a 0). Which means that the sender owned the sending domain rather than spoofing a legitimate one instead.

Relevance: Confirmed that the sender owned the domain and controlled the delivery of the IP address 203.0.113.10.

Supports which hypothesis? Initial hypothesis

Image 4 – Phishing email from the typosquatted domain

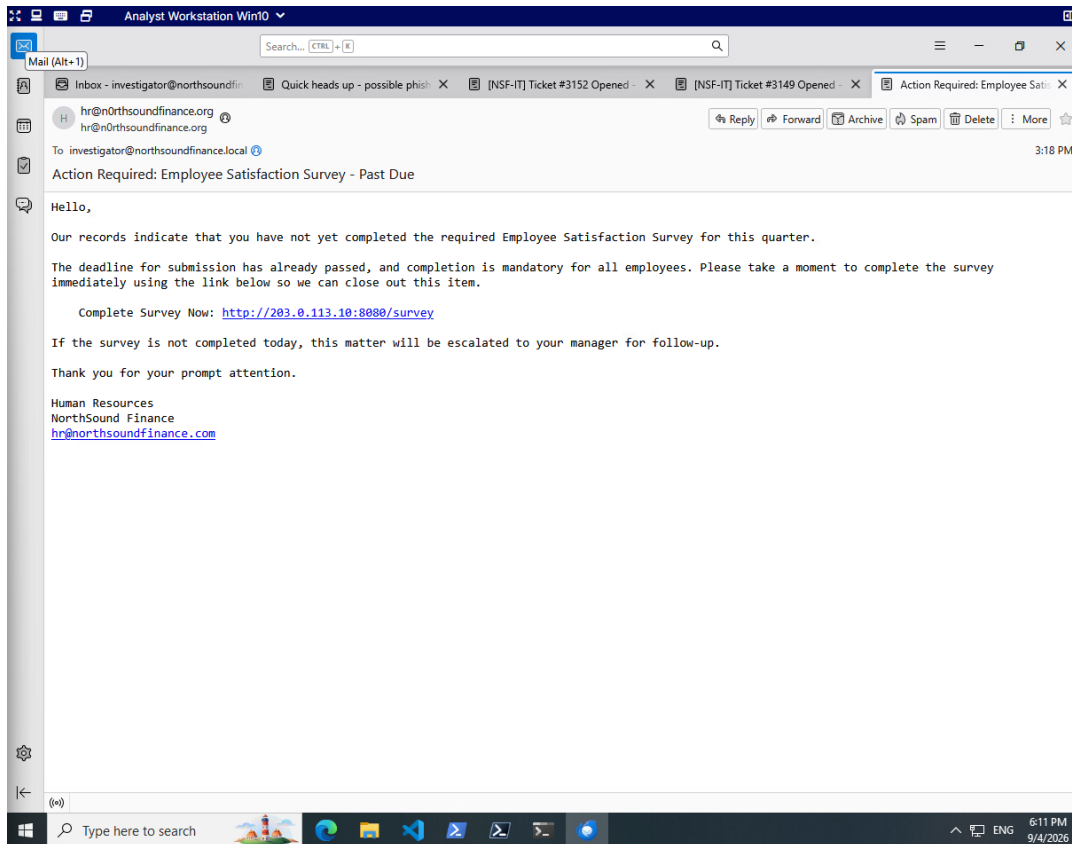
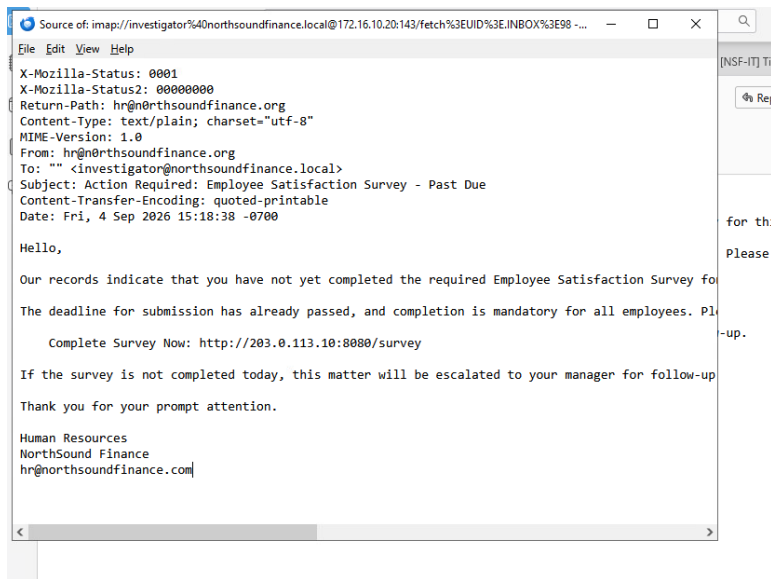


Image 5 – The source of the email shows that the message headers have no authentication present.



Evidence Log Entry 3 – SIEM Account Activity Review

Artifact Type: Log Data

Source: Elastic/Kibana SIEM (10.0.0.105)

Evidence: The events of authentication and privileges for c.ortiz. As well as Event ID 4672 and the Kerberos ticket requests.

Key Findings: An elevated logon activity was associated with the account, and the source address of the Kerberos activity had resolved to 10.0.0.149, which is Ortiz-workstation. This confirmed that the activity had originated from the user's (c.ortiz) machine rather than being a remote-based attack.

Relevance: This had ruled out the possibility of a remote attack as it shows that the focus of the investigation should be on the local workstation of the Ortiz-workstation environment.

Supports which hypothesis? Refutes hypothesis

Image 6 – SIEM results for c.ortiz that show privileges logon activity

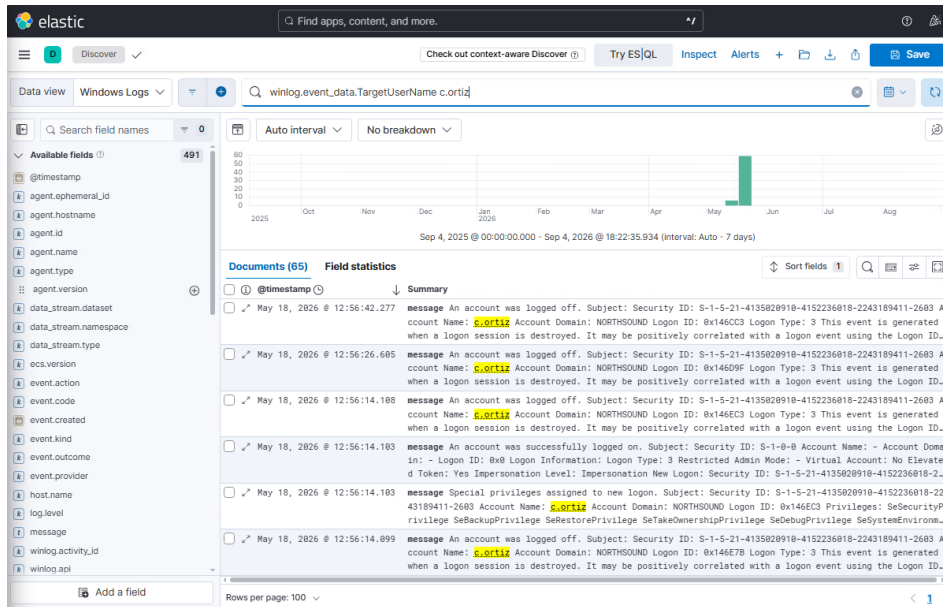
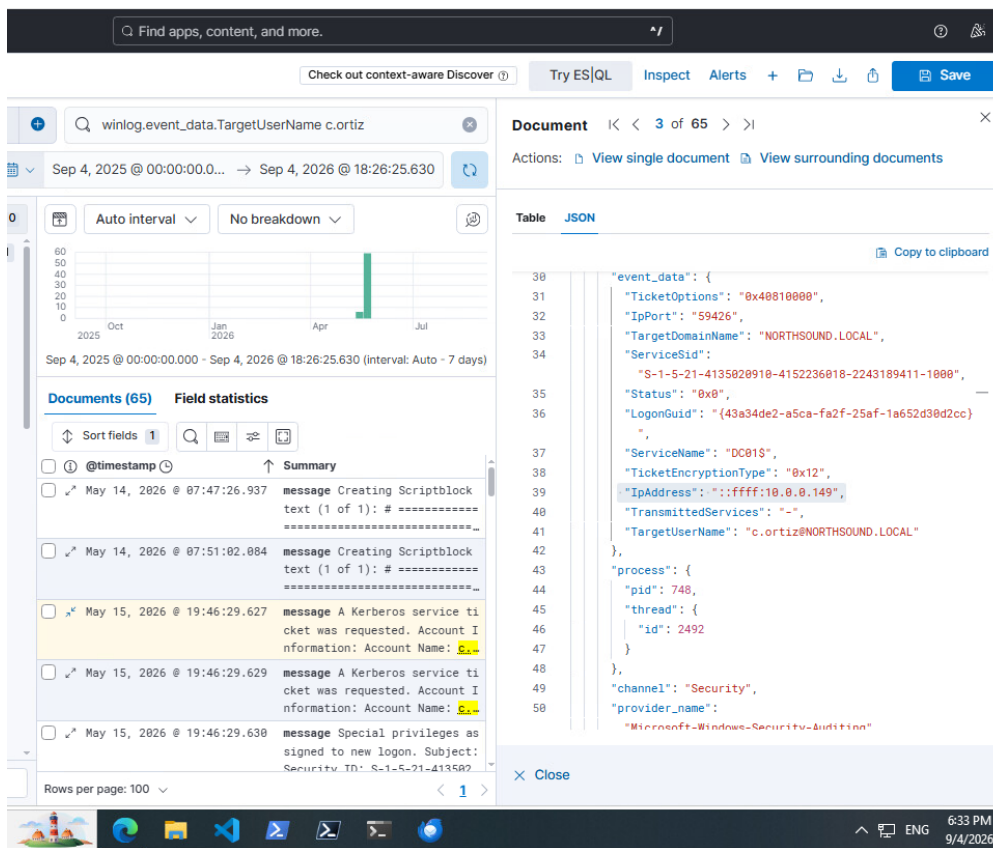


Image 7 – Event detailing the source of the IP ::ffff:10.0.0.149



elastic

Find apps, content, and more.

Evidence Log Entry 5 – A deeper look into the investigation.

Artifact Type: Configuration data

Source: ORTIZ-Workstation – The registry and the local accounts

Evidence: Looking at the registry keys, it shows that the HKCU Run Key was clean, and a discovery of a rogue local account was made. The svc_update was apparent and created on 9/4/2026, which had added itself to the local administrators group.

Key Findings: No unauthorized entries were found while the HKCU run key was checked. An attacker had created a local admin account (svc_update), which had allowed extra privileges. This malicious HKLM Run key entry pointed to the update.exe, and it was both identified and removed (More details within the Decision Log section).

Image 9 – Shows registry run clean

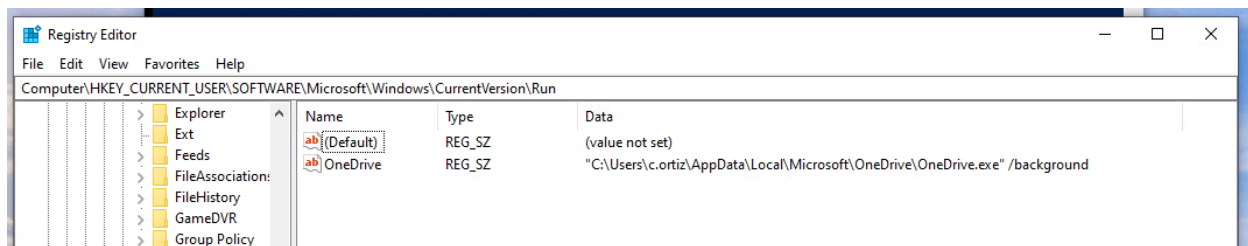
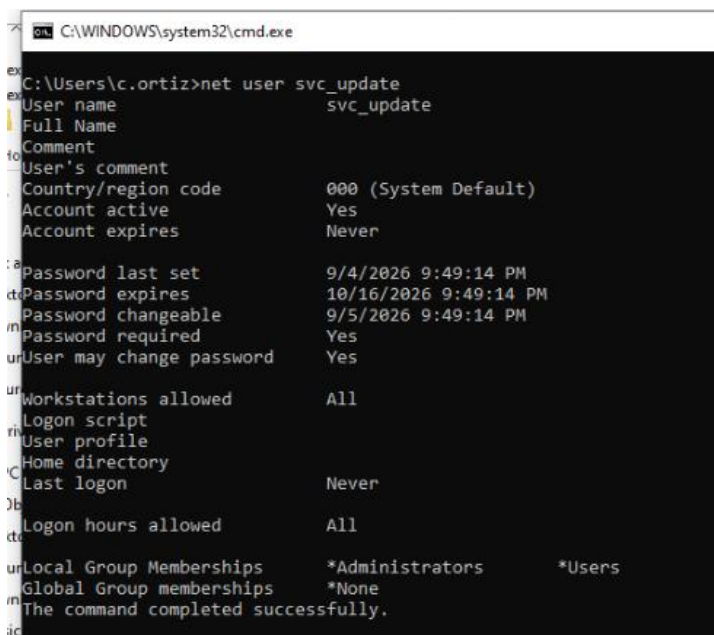


Image 17 – Shows rogue account details.



Decision Log

The decision log documents the remediation steps that were taken and why it was chosen, as well as the final outcome afterwards.

Decision Log Entry 1 – Resetting the Compromised Credentials

Action Taken: The password for c.ortiz was reset and changed within the Active Directory on the DC01 workstation.

System Affected: The Domain Controller in DC01 (10.0.0.9) – c.ortiz domain account

Reason for Action: The account's credentials were obtained by the attacker, and resetting the password invalidates the stolen password.

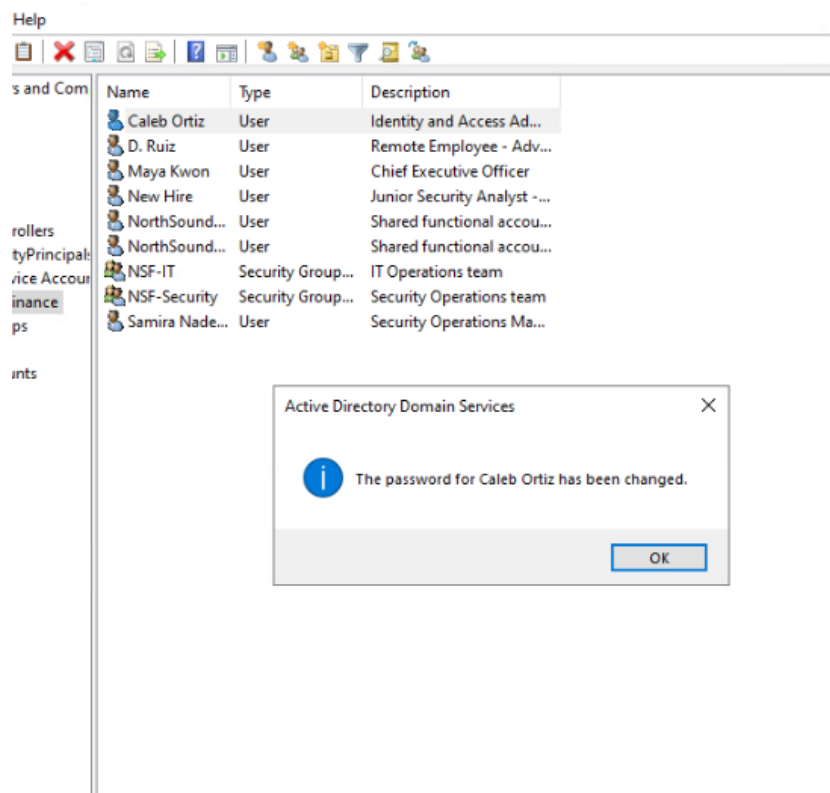
Expected Outcome: The stolen credentials become unusable for the attacker

Actual outcome: Password was reset and confirmed successfully

Was the Action Effective? Yes

Follow up required? No. The account was disabled (Entry 2).

Image 10 – The password reset on the c.ortiz account



Decision Log Entry 2 – Disabled Compromised Account

Action Taken: The c.ortiz account was disabled within the Active Directory

System Affected: The DC01 workstation (c.ortiz account)

Reason for Action: To contain the compromised account to prevent any further unauthorized activity while investigating until the remediation is completed.

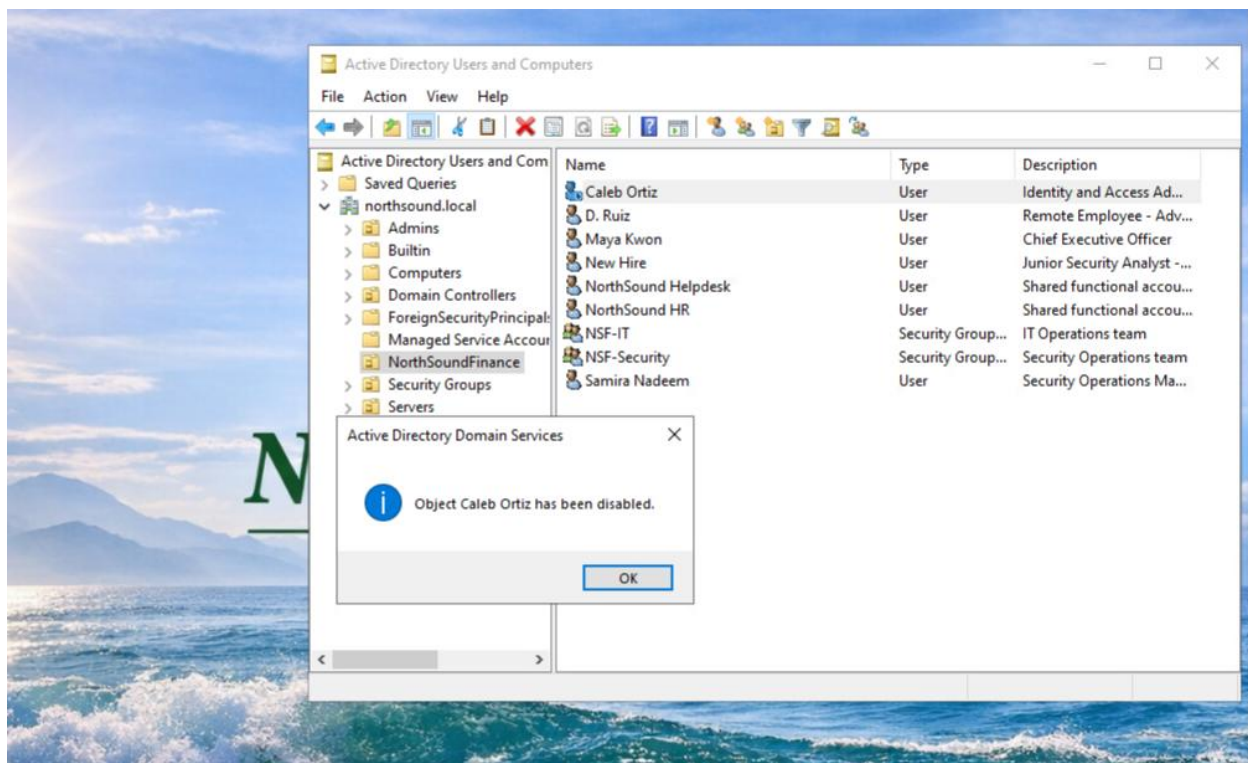
Expected Outcome: The account can't authenticate anything any longer

Actual Outcome: The account was disabled successfully.

Was the action effective? Yes.

Follow-up required? None.

Image 13 – Account Disabled



Decision Log Entry 3 - Blocking the attacker's infrastructure access

Action Taken: Created new firewall block rules both internally and externally via pfSense for the address 203.0.113.10 then verified the blocks.

System Affected: The internal firewall (10.0.0.1) and external firewall (172.16.10.1)

Reason for Action: Cutting off communication to the attacker's stolen credentials, they obtained, and remove the command and control access it has to the host. Based on the SOC incident response plan, it advises implementing a block via pfSense on the external firewall by using floating rules with logging enabled, which had been implemented, and the state table was reset.

Expected Outcome: The attacker had now become unreachable from the network

Actual Outcome: The ping to 203.0.113.10 had been confirmed, and it showed a 100% packet loss that also displayed that the survey page had timed out while also showing an error code message reading ERR_CONNECTION_TIMED_OUT.

Was the action effective? Yes.

Follow up required? No.

Image 11 – Firewall block

The screenshot displays the pfSense web interface for the Firewall Rules configuration. The breadcrumb navigation shows 'Firewall / Rules / LAN'. A green notification bar at the top states: 'The changes have been applied successfully. The firewall rules are now reloading in the background. Monitor the filter reload progress.' Below this, the 'Floating' tab is selected, showing a list of rules for the LAN interface. The rules table includes columns for States, Protocol, Source, Port, Destination, Port, Gateway, Queue, Schedule, Description, and Actions. The rules listed are: 'Anti-Lockout Rule' (active, 4/1.05 MIB), 'Block 203.0.113.10' (active, 0/0 B), 'Default allow LAN to any rule' (active, 11/1.09 GiB), and 'Default allow LAN IPv6 to any rule' (active, 0/0 B). At the bottom, there are buttons for 'Add', 'Delete', 'Toggle', 'Copy', 'Save', and 'Separator'.

States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
✓ 4/1.05 MIB	*	*	*	LAN Address	80	*	*		Anti-Lockout Rule	⚙️
✓ 0/0 B	IPv4 *	WAN address	*	LAN address	*	*	none			📌 🖋️ 🔄 🗑️ ✖️
✗ 0/0 B	IPv4 *	LAN subnets	*	203.0.113.10	*	*	none		Block 203.0.113.10	📌 🖋️ 🔄 🗑️ ✖️
✓ 11/1.09 GiB	IPv4 *	LAN subnets	*	*	*	*	none		Default allow LAN to any rule	📌 🖋️ 🔄 🗑️ ✖️
✓ 0/0 B	IPv6 *	LAN subnets	*	*	*	*	none		Default allow LAN IPv6 to any rule	📌 🖋️ 🔄 🗑️ ✖️

Buttons: ⬆️ Add ⬆️ Add 🗑️ Delete 🔄 Toggle 📄 Copy 💾 Save ➕ Separator

Image 14 – External block

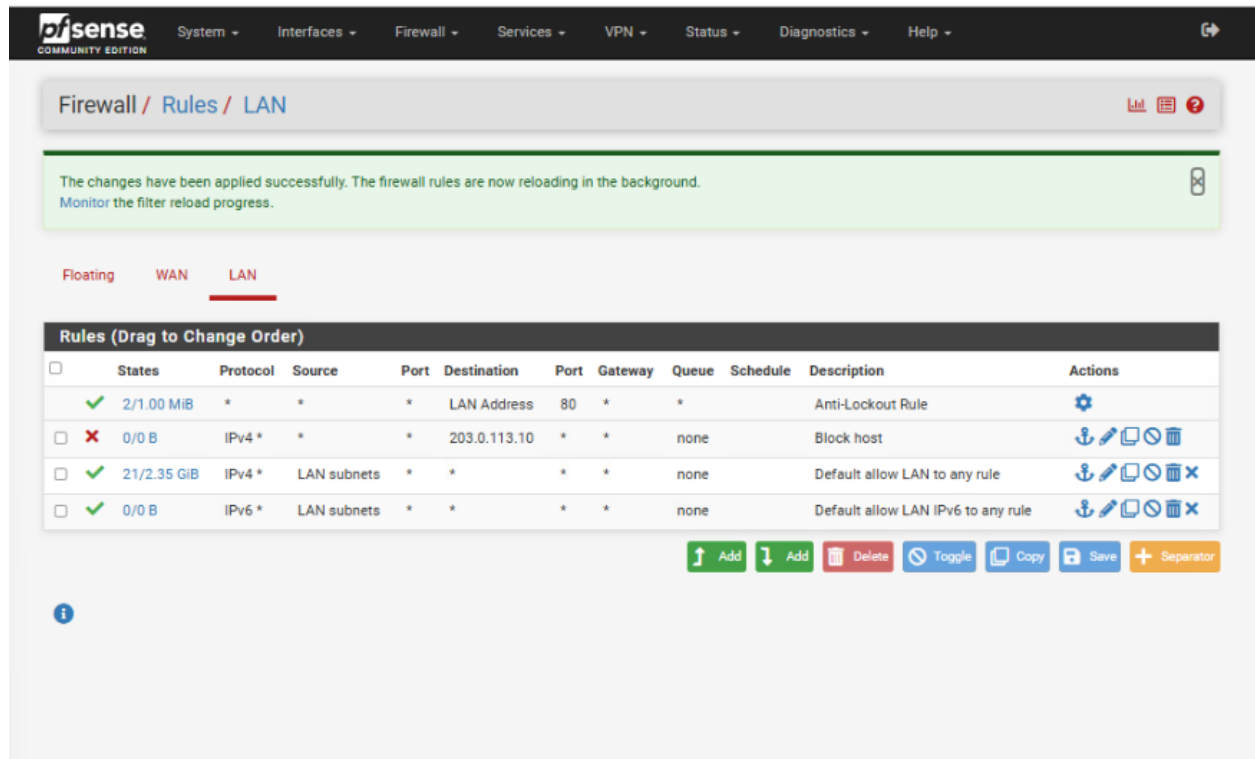
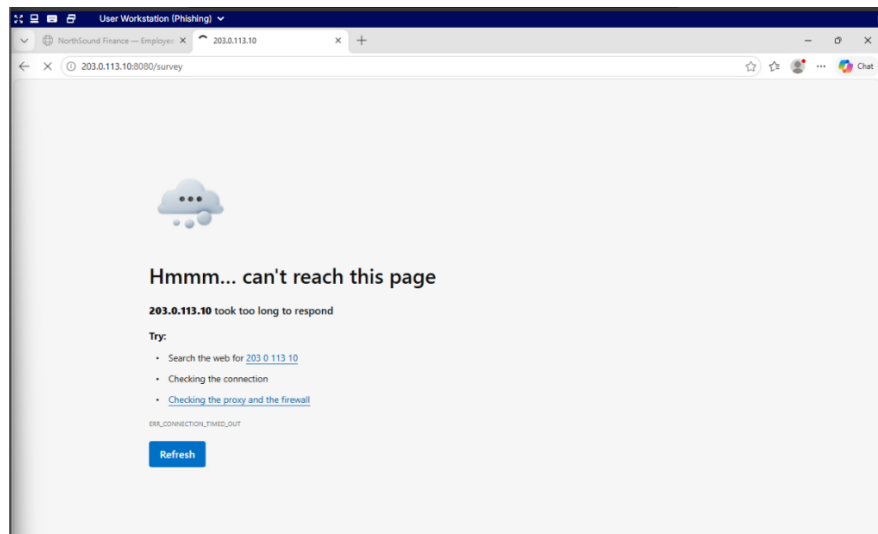


Image 12 – Block verified



Decision Log Entry 4 – Removing the malware

Action Taken: The running task of the update.exe process was ended within Task Manager. The HKLM Run key entry was also deleted, and the update.exe payload was permanently removed.

System Affected: ORTIZ-Workstation 10.0.0.149

Reason for Action: To remove the update.exe and its ability to auto-start so it won't run again.

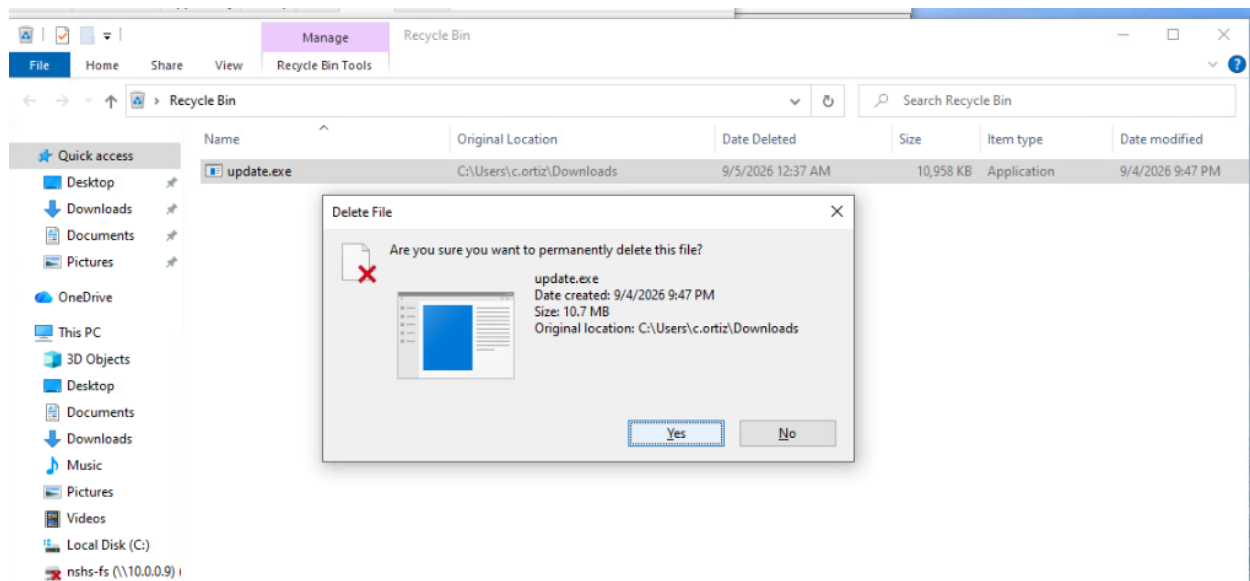
Expected Outcome: When the malware is removed, it will be unable to restart

Actual Outcome: The process of update.exe was ended, the registry key was deleted, and update.exe was completely removed permanently from the workstation.

Was the action effective? Yes.

Follow up required? No.

Image 16 – Malware removal



Decision Log Entry 5 – Removed the attacker

Action taken: Removed the both the c.ortiz and svc_update accounts from the local administrators group by deleting them.

System Affected: ORTIZ-Workstation 10.0.0.149

Reason for action: The attacker had gained access with privileged local presence because it had access to the credentials of the c.ortiz account (which it had obtained through the phishing link), and it used the svc_update account to blend in with the service accounts. It gained unauthorized local admin privileges.

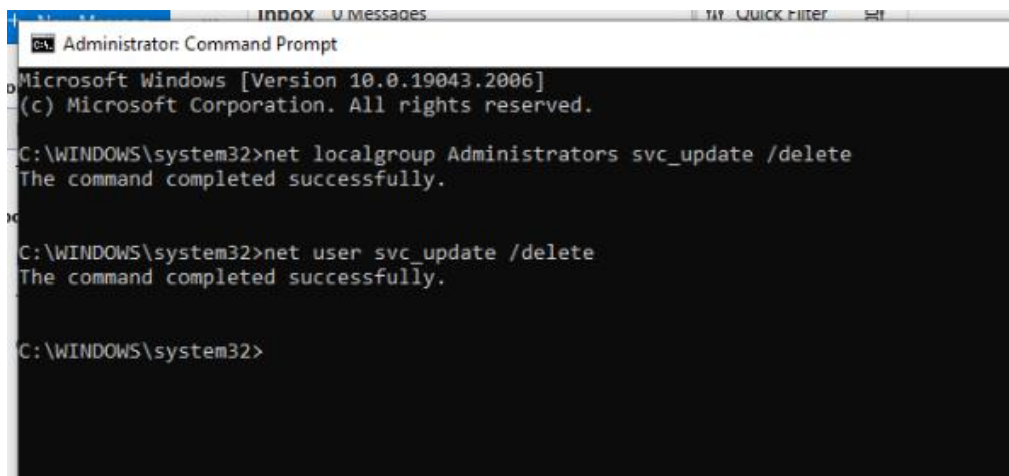
Expected outcome: Privileged and unauthorized account revoked.

Actual outcome: The svc_update was deleted and verified to be gone, c.ortiz was also removed from the local administrators group and that was also verified.

Was the action effective? Yes.

Follow up required? None, the manager had confirmed that the remediation was successful, and the ticket was closed.

Image 18 – Rogue account removed



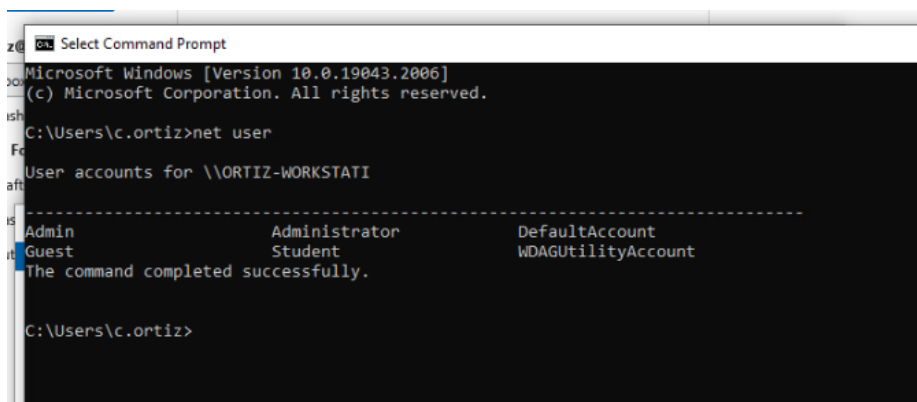
```
Administrator: Command Prompt
Microsoft Windows [Version 10.0.19043.2006]
(c) Microsoft Corporation. All rights reserved.

C:\WINDOWS\system32>net localgroup Administrators svc_update /delete
The command completed successfully.

C:\WINDOWS\system32>net user svc_update /delete
The command completed successfully.

C:\WINDOWS\system32>
```

Image 19 – Rogue account verified



```
Select Command Prompt
Microsoft Windows [Version 10.0.19043.2006]
(c) Microsoft Corporation. All rights reserved.

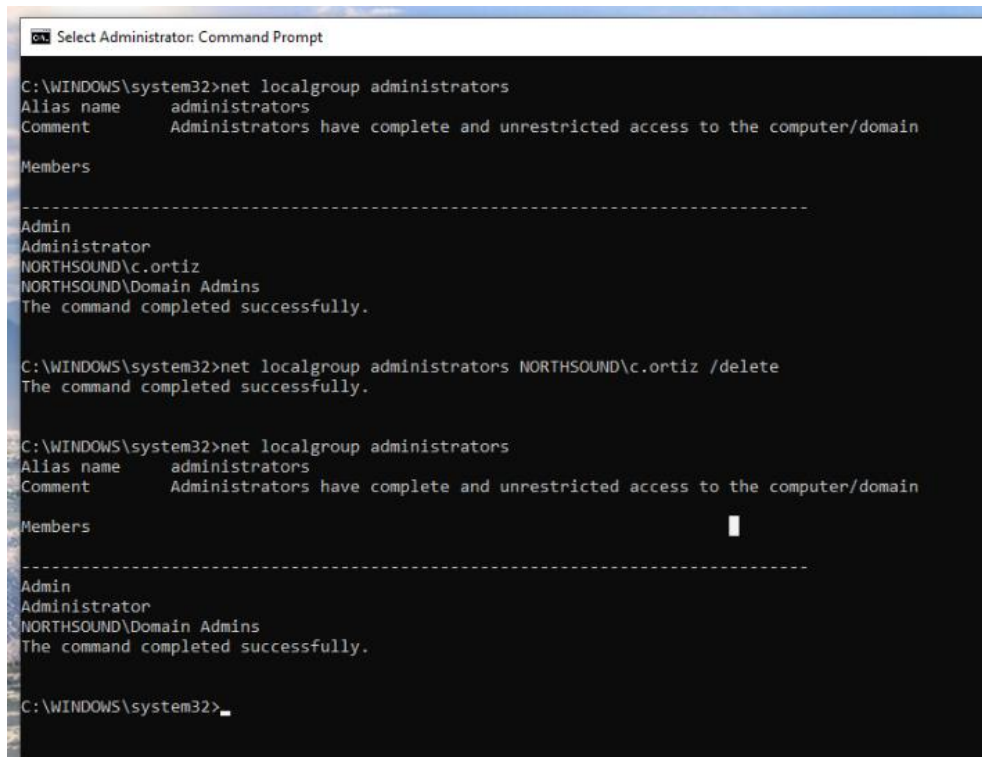
C:\Users\c.ortiz>net user

User accounts for \\ORTIZ-WORKSTATI
-----
Admin                Administrator        DefaultAccount
Guest                Student              WDAGUtilityAccount

The command completed successfully.

C:\Users\c.ortiz>
```

Image 20 – Local admin removed



```
C:\WINDOWS\system32>net localgroup administrators
Alias name     administrators
Comment       Administrators have complete and unrestricted access to the computer/domain

Members
-----
Admin
Administrator
NORTH SOUND\c.ortiz
NORTH SOUND\Domain Admins
The command completed successfully.

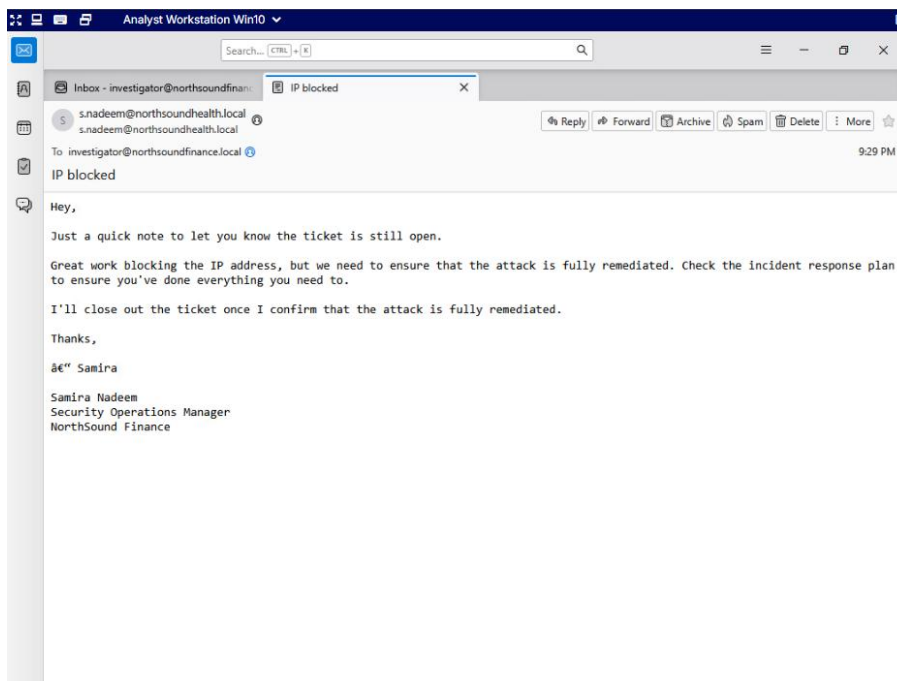
C:\WINDOWS\system32>net localgroup administrators NORTH SOUND\c.ortiz /delete
The command completed successfully.

C:\WINDOWS\system32>net localgroup administrators
Alias name     administrators
Comment       Administrators have complete and unrestricted access to the computer/domain

Members
-----
Admin
Administrator
NORTH SOUND\Domain Admins
The command completed successfully.

C:\WINDOWS\system32>
```

Image 15 – Manager block confirmed



Incident Summary

A. Brief Description

An employee named Caleb Ortiz (An access administrator) at NorthSound Finance had received a phishing email within his inbox that was typosquatted with the domain n0rthsoundfinance.org. The sender's email address was hr@n0rthsoundfinance.org. The employee had clicked the embedded link within the email and entered his credentials on a fraudulent page headlined "Employee Satisfaction Survey" hosted at the address 203.0.113.10:8080. The attacker was able to harvest the credentials and deliver malware that wrote an update.exe within the workstation, which established privileged local persistence. The systems that were affected were the ORTIZ-Workstation (10.0.0.149) and the domain account, as well as c.ortiz, which had compromised the account. During the investigation, the domain controller, mail server, and SIEM were used, which showed no evidence of any lateral movement that spread into any other systems. However, the incident was initially found through a user who self-reported (c.ortiz) to the Security Operations Manager, who had opened two IT help tickets #3149 and #3152.

B. Key Evidence

The key evidence that was discovered was the typosquatted email, headers, SIEM logs, payload download, the source IP confirming the activity derived from the local workstation, and the rogue svc_update within the local administrator account.

C. Root Cause Analysis

Identified Root Cause: A successful phishing attack was made by using social engineering tactics, in which a user submitted valid credentials, and the attacker was able to harvest these details and execute a payload that had established a local administrative access connection for the attacker.

Supporting Evidence: The stager download, update.exe being written in the workstation, the HKLM Run key entry, the svc_update within the administrator account, and the SIEM logs that show the GET request within the page of the survey.

Alternative Causes Considered: The consideration of an attack being done remotely from an external host was investigated, as well as the possibilities of an Active Directory-based escalation that may have occurred.

Why Ruled Out: The possibility of a remote attack was debunked because the Kerberos activity for c.ortiz originated from 10.0.0.149, which is the user's own workstation, not a remote host. The review of the Active Directory also showed that no additional domain accounts were created by the attacker, and there were no privilege changes within domain groups either. Which means the persistence was created and contained locally not within the Active Directory.

D. Impact Assessment

Type of Impact: Data exposure and unauthorized access open up possibilities of further compromises within the network

Description: The compromised user was an Identity and Access Administrator, which means they hold a certain level of authoritative privileges, and the credentials being compromised elevate the volume of risk that could occur. The impact was contained within a single workstation and an account that showed no signs of any lateral movement or other accounts being compromised.

E. Remediation Actions

Actions Implemented: Disabled and reset the compromised c.ortiz account. Blocked the host by adding rules within both external and internal firewalls for 203.0.113.10. Deleted and ended the active task for update.exe payload, as well as the Run key that existed within the registry keys. Also removed the rogue svc_update administrator account and the unauthorized local admin for the c.ortiz member.

Effectiveness: Yes, it was effective after these tests were completed. The attacker host was unreachable and showed 100% packet loss, all the persistences were removed with no artifacts remaining, and the Security Operations Manager had closed the incident ticket.

F. Recommendations

Short term: Re-enable the account only after changing the account password and verifying that all sessions and tokens for c.ortiz are revoked. Add the typosquatted domain to the email blocklist.

Long term: Implement an MFA (multifactor authentication) that adds an additional layer of security when logging in for the user. Add email authentication and anti-typosquatting controls. Apply the least privilege to any users that do not appear to be within the local administrators' member list, and also improve monitoring for any new admin accounts or run key changes.

G. Confidence & Limitations

Confidence Level: High

What was missing or uncertain: The update.exe was not dissected, so any of the data that was obtained could not be fully determined by the available logs. The investigation relied solely on the SIEM and endpoint data provided by the lab.